

Incident Response in the Cloud

ENPM665

Thomas Dineen



A. JAMES CLARK
SCHOOL OF ENGINEERING



Overview

What is Cloud Incident Response (CIR)?

Components of CIR

Incident Response Phases

Cloud Provider Tools for Detection and Protection



What is Cloud Incident Response

Cloud Incident Response (Cloud IR) is the structured process of **detecting**, **investigating**, **containing**, and **recovering** from cybersecurity incidents that occur within cloud environments

It's a specialized discipline that adapts traditional incident response principles to the unique challenges of cloud computing.

Components of Cloud Incident Response

- **Preparation:** Planning, documenting and resourcing
- **Detection:** Identifying suspicious activity using cloud-native tools (e.g., AWS GuardDuty, Azure Defender, GCP SCC)
- **Assessment:** Evaluating the scope, impact, and severity of the incident
- **Containment:** Isolating affected resources to prevent further damage.
- **Eradication:** Removing the threat from the environment (e.g., deleting malicious containers, revoking compromised credentials).
- **Recovery:** Restoring services and verifying that systems are clean and secure
- **Post-Incident Analysis:** Conducting root cause analysis and updating playbooks to prevent recurrence

Importance of Cloud Incident Response

Cloud incident response is of paramount importance in today's digital landscape, where businesses and organizations heavily rely on cloud services to store, process, and manage their critical data and applications

Cloud incident response refers to the process of effectively addressing and managing **security breaches**, **data breaches**, and other **cybersecurity** incidents that impact cloud-based resources.

Security Breach vs Data Breach vs Incident

Security Breach: Unauthorized access to a system, network, or resource, often involving malicious intent

Data Breach: A security breach that results in unauthorized access to sensitive data, such as PII or financial records

Cybersecurity Incidents: System malfunctions, software bugs, and minor data leaks which do not necessarily involve unauthorized access to sensitive data

Data Protection and Privacy

Cloud incident response helps protect sensitive data stored in the cloud from unauthorized access, data breaches, and potential leakage

Rapid and effective response can **limit the exposure** of sensitive information, minimizing the impact on individuals and the organization's reputation

Business Continuity

Cloud services are critical for business operations. Any disruption, whether due to a cyberattack, a technical glitch, or other incident, can lead to downtime and financial losses

Effective incident response helps to minimize downtime and ensure business continuity.

Rapid Detection and Mitigation

Cloud incidents can escalate quickly

A well-defined incident response plan enables the swift **detection, containment**, and **mitigation** of threats, preventing the incident from spreading and causing further damage.

Rapid Detection and Mitigation

Detection involves identifying the presence of a threat

Containment limits the spread of the threat

Mitigation includes actions to reduce the impact of the incident

Compliance and Legal Obligations

Many industries are subject to **regulatory compliance** requirements regarding data protection and incident reporting

Cloud incident response ensures that an organization meets its legal obligations and avoids potential penalties for non-compliance.

Reputation Management

A data breach or security incident can severely damage an organization's **reputation** and **erode trust** among customers, partners, and stakeholders

A well-managed incident response demonstrates **transparency, accountability**, and a commitment to resolving issues, which can help mitigate reputation damage

Lessons Learned and Continuous Improvement

After an incident, a thorough analysis is conducted to understand what happened and why

These insights can be used to **enhance security measures**, **update policies**, and **improve** incident **response** strategies for the future

Prevention and Preparedness

Incident response is not just about reacting to incidents; it's also about being **proactive**.

By identifying vulnerabilities and weak points in cloud infrastructure, an organization can take measures to strengthen its security posture and reduce the likelihood of incidents occurring

Adapting to Cloud-Specific Threats

Cloud environments have unique security challenges that require specialized knowledge

Cloud incident response takes these challenges into account, addressing issues related to **shared responsibility** models, **cloud misconfigurations**, and the **dynamic** nature of cloud resources

Third-Party Risks

Cloud services often involve third-party vendors and providers

An incident involving a service provider can have cascading effects on multiple organizations

A robust incident response plan should include strategies for handling incidents involving third parties

Incident Reporting Requirements

May vary by jurisdiction and Industry

GDPR Compliance requires organizations must report personal data breaches to authorities within 72 hours

The Cyber Incident Reporting for Critical Infrastructure Act of 2022 (CIRCIA) mandates that covered entities must report significant cyber incidents within 72 hours of the incident's occurrence and ransomware payments within 24 hours

Digital Forensics and Incident Response (DFIR)

Focuses on the **identification**, **investigation**, and **remediation** of cyberattacks

You can't just rely on traditional DFIR

Why?

Traditional digital forensics/incident response tools are unaware of your cloud vendor's API activity



You can't just rely on traditional DFIR

Traditional DFIR will help find system compromises, but **NOT** IAM/API compromises

You also can't just go "pull the drive and image it" like traditional on-prem

NIST Incident Response Phases

- Preparation
- Detection and Analysis
- Containment
- Eradication and Recovery
- Post-Incident Activity



<https://csrc.nist.gov/projects/incident-response>

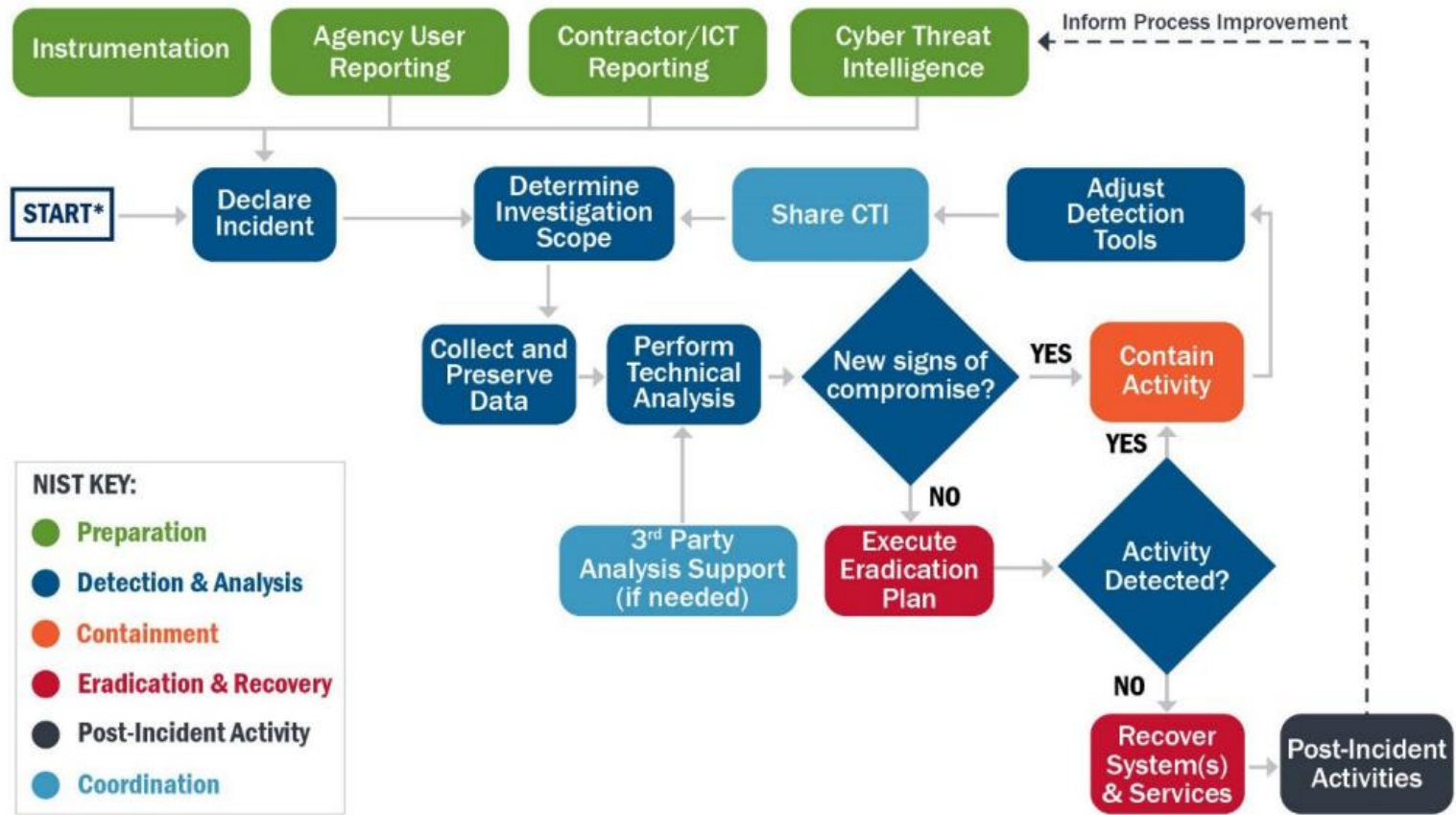


Figure 1: Incident Response Process

Preparation Phase

- Documenting and understanding **policies** and **procedures** for incident response
- **Instrumenting** the environment to detect suspicious and malicious activity
- Establishing **staffing** plans
- Educating users on cyber threats and notification procedures (**COOP**)
- Leveraging Cyber Threat Intelligence (CTI) to **proactively identify** potential malicious activity

Detection and Analysis

- Declare Incident – Report to Authorities
- Determine Investigation Scope
- Collect and Preserve Data
- Perform Technical Analysis
- Correlate Events and Document Timeline
- Identify Anomalous Activity
- Gather Incident Indicators

Containment

- Prevent further damage and reduce the immediate impact of the incident by **removing** the adversary's **access**
- Determine **impact** to **mission operations**, availability of services
- Isolating impacted systems and network segments
- Capturing forensic images to preserve evidence
- Updating firewall filtering
- Blocking (and logging) of unauthorized accesses, blocking malware sources
- Closing specific ports and mail servers or other relevant servers and services
- Changing system admin passwords, rotating private keys, updating secrets

Eradication and Recovery

- Remediating all infected IT environments
- Reimaging affected systems (often from 'gold' sources), rebuilding systems from scratch
- Replacing compromised files with clean versions
- Installing patches
- Monitoring for any signs of adversary response
- Testing systems thoroughly



Post-Incident

- Document the incident
- Inform leadership
- Harden the environment to prevent similar incidents
- Apply lessons learned to improve
- Ensuring root-cause has been eliminated or mitigated
- Identifying organizational policy and procedural problems to address

Credential Compromise via Phishing



Forensics / IR in the Cloud

More difficult than traditional on-prem incident response

Ex: CloudTrail logs and CloudWatch flow logs as “flight recorders”

Ahead of time set up **Forensics IAM role** to

- Isolate system
- Dump snapshot of volume storage and export to object
- Do your forensics work with a copy of the snapshot
- Can use traditional forensics tools in an instance out in the cloud, or can export/download the snapshot and analyze locally

CloudTrail – What to watch

- Unusual activity
- Failed authentication
- IAM changes
- Configuration changes
- Data access or modification
- Resource usage

Forensics: Analyze Compromised Drive

1. Take a Snapshot of the affected system's storage
2. Create a Volume from that Snapshot
3. Create Analysis system (Same AZ as Snapshot!)
4. Mount Snapshot Volume to Analysis system

Create Snapshot

Create Snapshot

Volume ⓘ

vol-055d49165c08d7065

Name ⓘ

suspect-volume

Description ⓘ

Suspected Compromised

Encrypted ⓘ

No

Cancel

Create

Create Snapshot

✓ Snapshot Creation Started

View snapshot [snap-0ab7ec392642e6ca4](#)

Close



Create Volume from Snapshot



Create Analysis Instance

Ensure it's in the same Availability Zone as your Snapshot'd Volume!

Step 3: Configure Instance Details

Configure the instance to suit your requirements. You can launch multiple instances from the same AMI, request Spot instances to take advantage of lower prices.

Number of instances	1	Launch into Auto Scaling Group
Purchasing option	☐ Request Spot instances	
Network	vpc-89c0a3ee ENPM685 (default)	Create new VPC
Subnet	subnet-9d4f48b7 Default in us-east-1a 4091 IP Addresses available	Create new subnet
Auto-assign Public IP	Use subnet setting (Enable)	
IAM role	None	Create new IAM role
Shutdown behavior	Stop	
Enable termination protection	☐ Protect against accidental termination	
Monitoring	☐ Enable CloudWatch detailed monitoring Additional charges apply.	
Tenancy	Shared - Run a shared hardware instance Additional charges will apply for dedicated tenancy.	
▼ Network interfaces		



Attach Volume to Analysis Instance

Attach Volume

Volume ⓘ

vol-016c855642e5ccbdb in us-east-1b

Instance ⓘ

i-00d200955f9d507fb

in us-east-1b

Device ⓘ

/dev/sdf

Linux Devices: /dev/sdf through /dev/sdp

Note: Newer Linux kernels may rename your devices to /dev/xvdf through /dev/xvdp internally, even when the device name entered here (and shown in the details) is /dev/sdf through /dev/sdp.

Cancel

Attach

Attach Volume to Analysis Instance

```
[ubuntu@ip-172-31-9-220:~/analyze$ ls
bin  etc      lib      media  proc  sbin  sys  var
boot home    lib64    mnt    root  snap  tmp  vmlinuz
dev  initrd.img lost+found opt     run   srv   usr
[ubuntu@ip-172-31-9-220:~/analyze$ ls -l home/ubuntu/
total 0
-rw-rw-r-- 1 ubuntu ubuntu 0 Jul 17 17:57 pwn3d
ubuntu@ip-172-31-9-220:~/analyze$
```

Incident Response in the Cloud

How is it detected?

- Traditional log review (auth.log, Apache logs, etc)
- CloudTrail logs
- Notifications and Events
- Billing alerts (Your bill just shot up to \$20k/hr)



Protect those API keys

One of the biggest issues in the cloud is when API keys are accidentally posted publicly

Can lead to disaster, or just a huge bill from someone spinning up 50k instances to mine for Ethereum.



CloudTrail

We will review the CloudTrail exercise in the assignment section in Canvas.

CloudWatch Flow Logs

- Records each time **packets** enter or leave a **VPC**
- Monitor for DENY connections, gives you Security Group and ACL denies
- These are kind of a mix of **firewall** logs and **netflow** logs
 - You get the allow/deny
 - You get more context/metadata of the conversation (ex how long the conversation was, how much was transferred, etc)

AWS Billing Alerts

- A canary on if something it out of the norm
- AWS allows you to set a billing alert if you **exceed** a **threshold** you set. Can do this on as frequently as you want.
- If your monthly bill is usually \$4500/mo and you've hit that amount 4 days into the billing cycles there may be a problem
 - See compromised credentials/API keys, rogue actor, etc
- AWS Support can help with this and will contact you if they see something way out of the norm

Memory Forensic Tools + The Cloud

Yes you can dump memory image with your typical toolsets (FTK Imager, LiME, etc) and then analyze as you see fit

FTK Imager is a standalone disk imaging program that allows users to create forensic images of local hard drives, CDs/DVDs, thumb drives, and other USB devices

LiME (Linux Memory Extractor) is a tool for capturing memory images from Linux systems

Lambda

- Lamba (FaaS)
- Inversion of Control (IoC) Framework
 - In IoC, container takes control of object creation, dependency management, and lifecycle management
- Long execution times
- High error rates
- CloudTrail high denials for the Lambda role

Lambdash

- AWS Lambda Shell Hack
 - <https://github.com/alestic/lambdash>
- Gathers basic underlying system info
- Determines writability/persist ability
- Warmness checks (is the provider recycling sandboxes)
- Contents of the environment

Lambdash

Let's us explore how the environment changes, when it's patched, and let's us verify that AWS is doing their job

Find Newly Spun Up Instances

```
aws ec2 describe-instances --region us-east-1 \
--query
'Reservations[].Instances[?LaunchTime>=`2017-
07-01`][].{id: InstanceId, type: InstanceType,
launched: LaunchTime}'
```

Google Vault

Vault is an information governance and eDiscovery tool designed for Google Workspace (Google Apps)

<https://ediscovery.google.com>

Google Vault Pro Tip

If you delete a Google user their data gets deleted too

Better to **suspend** a user in Google so their email can still be searched through even after they are gone

When dealing with Google Vault and user account deletion, **prioritize data preservation**

Instead of deleting accounts, consider **archiving users** or **transferring data** to avoid data loss and **ensure compliance** with retention policies



Why is threat detection so hard?



Large datasets

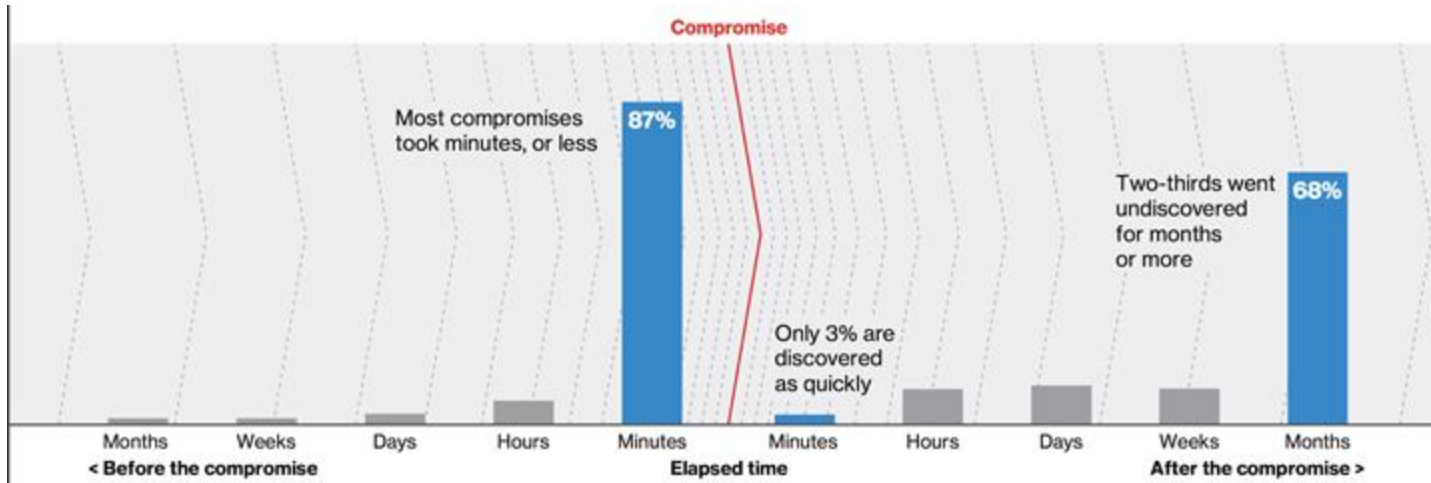


Signal to noise



Skills shortage

Detecting breaches



Source: 2018 Data Breach Investigation Report, Verizon, 11th edition 2018

Days to Detect and Remediate

As of **2024**, the mean number of days to identify the data breaches was **194 days**, four percent less than in the previous year.

The mean time companies needed to **contain** the breaches in 2024 was **64 days**.

In comparison, in 2022, it took organizations **207 days** to identify and **70 days** to address the data breaches

Verizon 2025 Data Breach Investigations Report



of breaches were linked to third-party involvement, twice as much as last year, and driven in part by vulnerability exploitation and business interruptions



increase in attackers exploiting vulnerabilities to gain initial access and cause security breaches compared to last year's report



of perimeter-device vulnerabilities were fully remediated by organizations in the past year, while almost half remained unresolved



of all breaches analyzed showed ransomware was present, marking a notable rise from last year's report

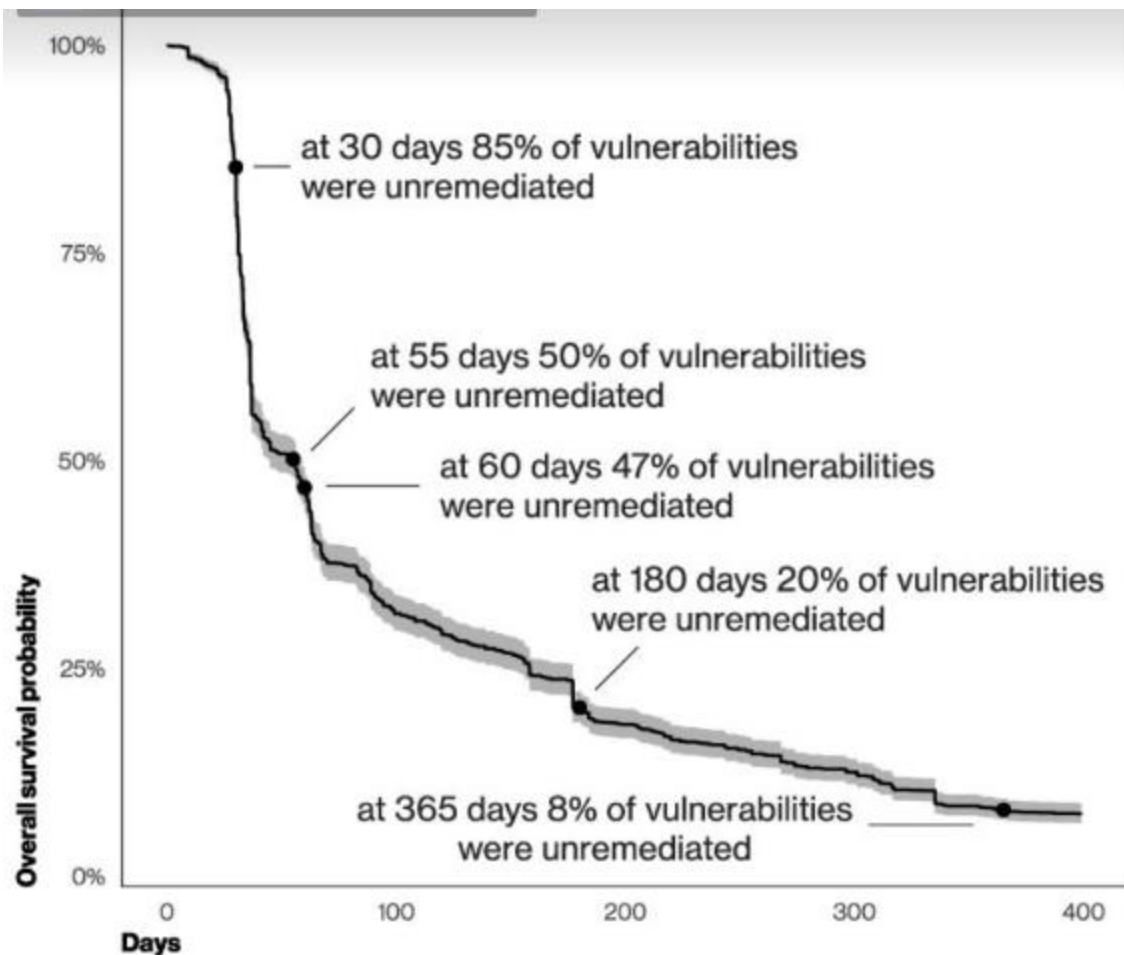


Figure 19. Survival analysis of CISA KEV vulnerabilities



AWS Security Services



AWS Security, Identity, and Compliance Services

By function type

Authorization



IAM



AWS RAM



AWS Organizations

Authentication



Amazon
Cognito



AWS SSO



Amazon Directory
Service

Protected stores



AWS CloudHSM



AWS KMS



AWS Secrets
Manager



AWS Certificate
Manager

Visibility



AWS Artifact



AWS Security
Hub

Enforcement



Amazon GuardDuty



Amazon Inspector



Amazon Macie



AWS WAF



AWS Shield



Threat Detection – Log Inputs



AWS CloudTrail

Track user activity and API usage



VPC Flow Logs

IP traffic to/from network interfaces in your VPC



CloudWatch Logs

Monitor apps using log data, store & access log files



DNS Logs

Log of DNS queries in a VPC when using the VPC DNS resolver



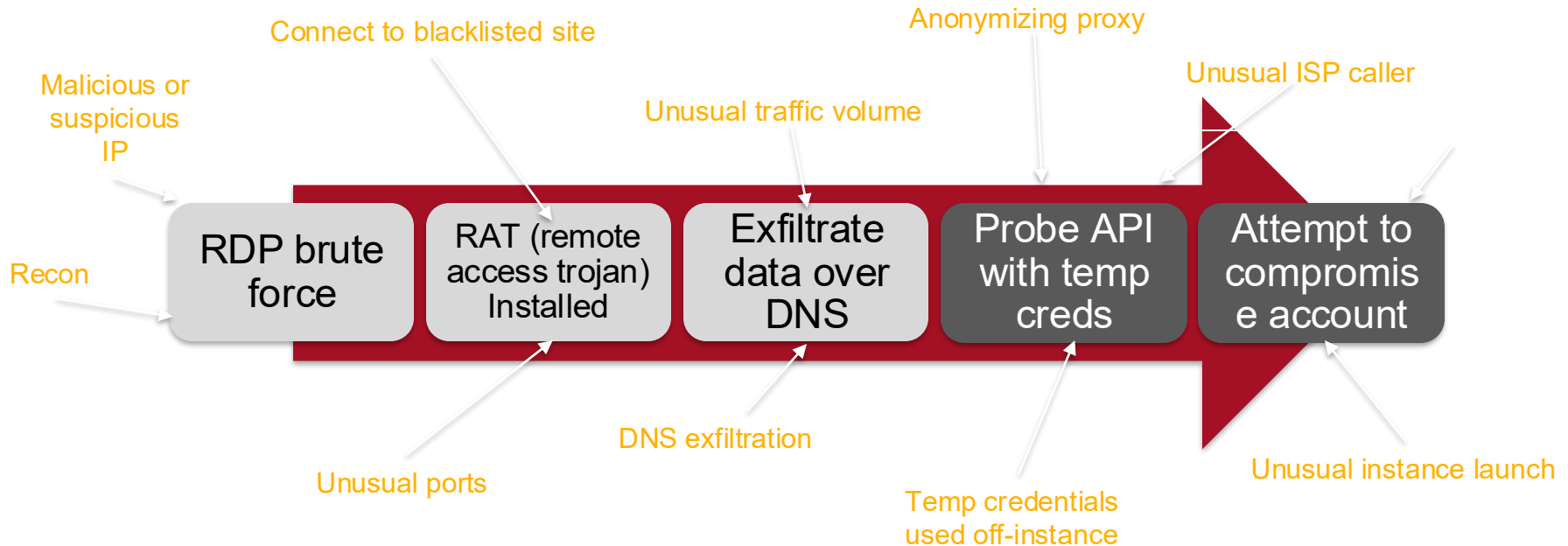
AWS GuardDuty

Threat detection service

- Continuously **monitors**, **analyzes**, and **processes** AWS data sources and logs in your AWS environment
- Compromised and exfiltrated AWS credentials
- Data **exfiltration** and **destruction** that can lead to a ransomware event
- Unauthorized crypto mining activity
- Detection of presence of malware
- Indications of unauthorized



What Can GuardDuty Detect



Azure Microsoft Defender for Cloud

- Unified security management and advanced threat protection across **hybrid** cloud workloads
- Threat detection for VMs, containers, databases, and more
- Integration with Microsoft Sentinel for SIEM capabilities
- Regulatory compliance assessments
- Uses Microsoft Threat Intelligence and analytics



GCP - Security Command Center (SCC)

- Centralized security and risk management platform for GCP resources.
- Asset inventory and vulnerability scanning
- Threat detection via Event Threat Detection (ETD)
- Integrates with Chronicle and other Google security tools
- Supports misconfiguration detection and policy violations



Detecting Known Threats (AWS)

Threat intelligence

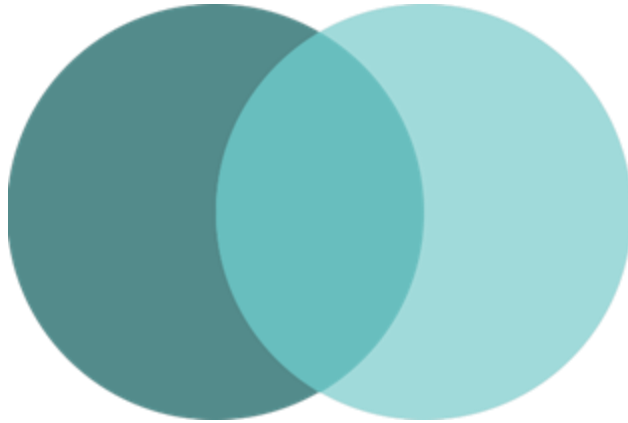
- Feeds:
 - AWS Security
 - Commercial – (ex: CrowdStrike, Proofpoint)
 - Open source
 - Customer provided - "format":
"[TXT|STIX|OTX_CSV|ALIEN_VAULT|PROOF_POINT|FIRE_EYE]",
- Known malware infected hosts
- Anonymizing proxies (masking the user's IP address)
- Sites hosting malware and hacker tools
- Cryptocurrency mining pools and wallets



Amazon Macie

Understand your data

Natural Language
Processing (NLP)



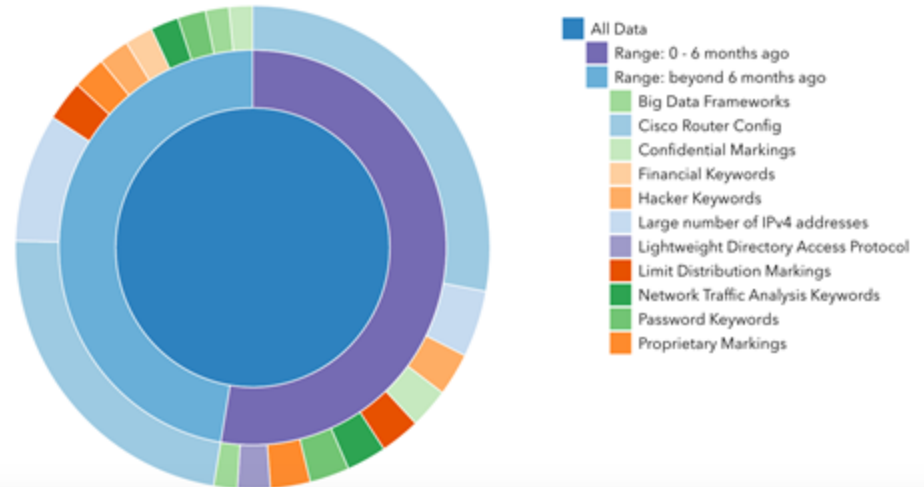
Understand data access

Predictive User
Behavior Analytics
(UBA)

Macie Content Classification

- PII and personal data
- Source code
- SSL certificates, private keys
- iOS and Android app signing keys
- Database backups
- OAuth and Cloud SaaS API Keys

Amazon S3 Overview by DLP Theme - minRisk: (7)



Macie - Discover and Alert on Global Permissions

- Works on Amazon S3 bucket AND object policies
- Use AWS **Lambda** to approve or automatically remediate overly permissive policies
 - Delete the object
 - Revoke access—bucket or object
 - Update IAM policies
 - Suspend user
- Prioritize by PII impact and Data Loss Prevention (DLP) risk

Threat Detection – Triggers



AWS Config rules

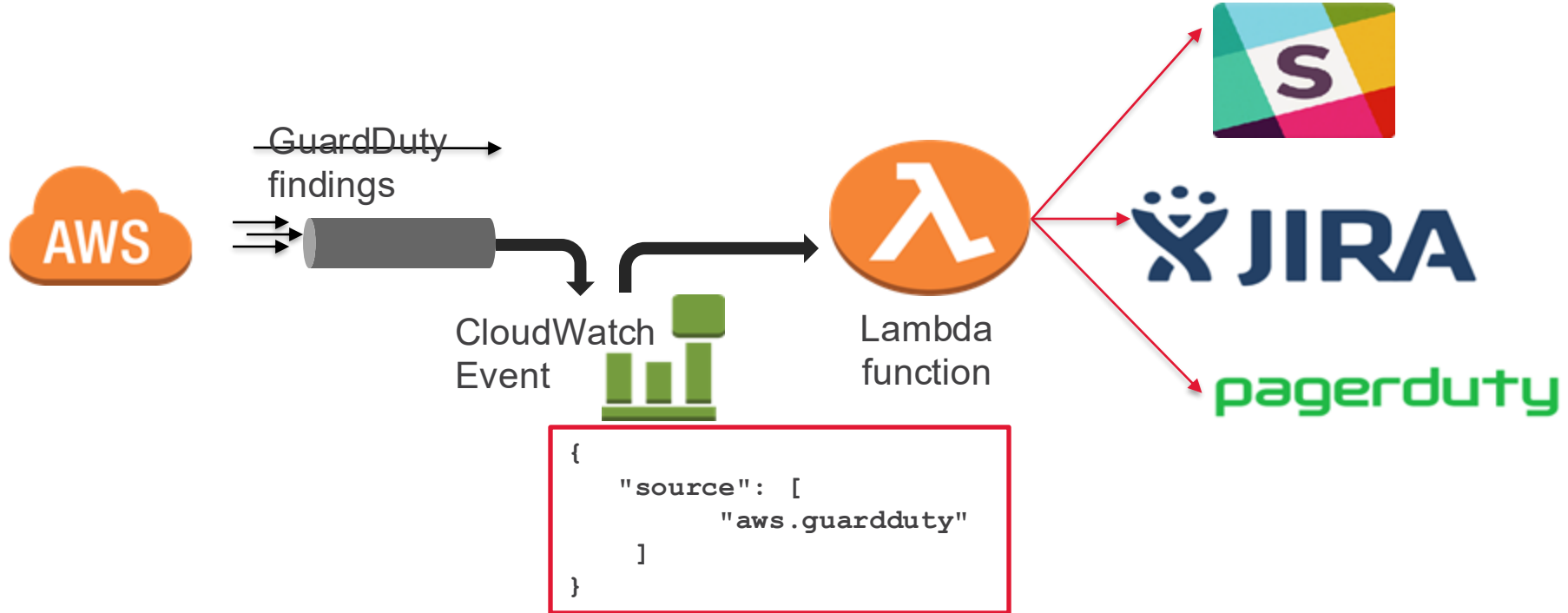
Continuously tracks your **resource configuration** changes and if they violate any of the conditions in your rules



Amazon CloudWatch Events

Delivers a near real-time stream of system events that describe changes in AWS resources

Amazon CloudWatch Events



AWS Config Rules

A continuous recording and assessment service

- How are my resources configured over time?
- Is a change that just occurred to a resource, compliant?

